



2016 中国互联网安全大会  
China Internet Security Conference

协同联动 共建安全+命运共同体

# 移动平台应用软件隐私威胁与保护

张源

博士、讲师  
复旦大学系统软件与安全实验室

# 移动平台隐私威胁态势严峻



中国互联网安全大会



360互联网安全中心

< 发现

朋友圈



晕！今天快递公司让我收一个快递！说要到付30元的，问我要不要。我问是哪儿发来的，他说出了一个我熟悉的小地方（让人感觉非常可信，如果我刚好出差，我可能就让家人付费收了这个快递）。

刚好我在家，然后我就去看了一下。是一个什么佛缘的很小的包裹，使用的是我的家庭具体到房号的详细地址，上面写的是代收快递费30元！..... 没有具体发件人信息，只写了一个发件人的地址，显然是一个骗局.....

这就是地址信息泄漏带来的被欺诈的风险 🙄

收起



22分钟前



# 移动平台隐私威胁新特点



中国互联网安全大会



360互联网安全中心

移动平台上，用户输入的信息是隐私数据的主要来源。





# 针对用户输入隐私的攻击开始兴起



图 1 正常应用的启动界面

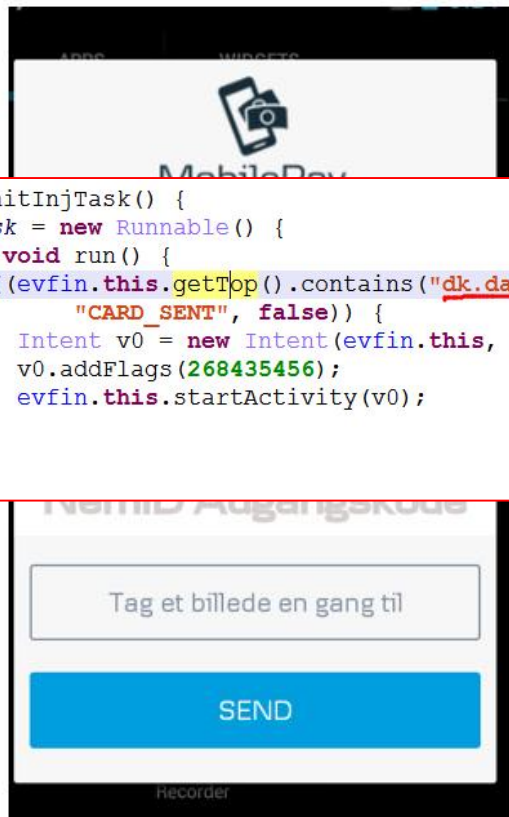


图 2 SlyRogue 病毒的仿冒界面

```
private void initInjTask() {  
    this.injTask = new Runnable() {  
        public void run() {  
            if((evfin.this.getTop().contains("dk.danskebank.mobilepay")) && !evfin.settings.getBoolean(  
                "CARD_SENT", false)) {  
                Intent v0 = new Intent(evfin.this, gmkxrny.class);  
                v0.addFlags(268435456);  
                evfin.this.startActivity(v0);  
            }  
        }  
    };  
}
```

来自AVL Team. 高能预警：丹麦“支付宝” MobilePay被盯上了！  
<http://blog.avlsec.com/2016/06/3339/mobilepay/>

# 用户输入的隐私 (UIP) 数据

Create account

Full name  
First name, last name

Skype Name  
6-32 characters

Password  
6-20 characters

Repeat password  
6-20 characters

Email  
someone@example.com

Mobile number  
Phone number (e.g. +44 1234567)

☒ Yes, send me Skype news and promotions.

账号和密码信息

amazon

Or enter a new shipping address

City:

State/Province/Region:

ZIP:

地址信息

银行卡支付

中国银行(信用卡)

6227 6121 4583

727114

重获验证码(2)

☒ 同意《协议》并保存卡信息, 支付更便捷

支付金额¥95

立即支付

资金账户信息

## UIP数据特点

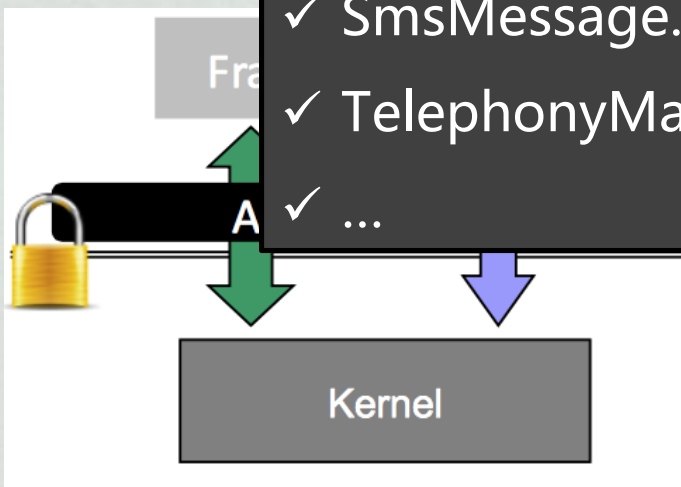
- UIP类数据格式各异
- UIP类数据获取接口非规整
- UIP类数据的获取形式多样

## 隐私泄露检测

- TaintDroid [OSDI 10]
- AppIntent [CCS 12]
- VetDroid [Security 13]
- FlowDroid [Security 14]

### 主要关注的敏感数据

- ✓ LocationManager. getLastKnownLocation()
- ✓ ContentResolver.query(CONTACT\_URI)
- ✓ SmsMessage. getMessageBody ()
- ✓ TelephonyManager. getLine1Number()
- ✓ ...



```
c = taint_source()
```

```
...
```

```
a = b + c
```

```
a)
```

- FlaskDroid [Security 13]
- ASM [Security 14]

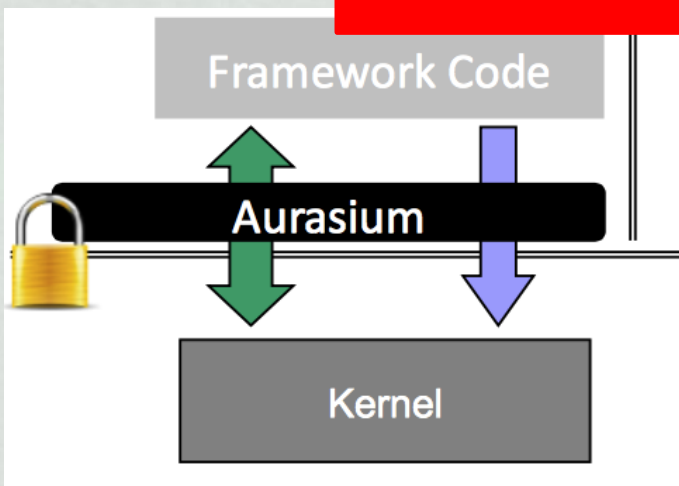
## 隐私泄露检测

- TaintDroid [OSDI 10]
- AppIntent [CCS 13]
- VetDroid [CCS 13]
- FlowDroid

```
c = taint_source()  
...  
a = b + c  
...  
_send(a)
```

现有工作：

无法适用于UIP隐私数据的保护



## 访问控制机制

- Auriasium [Security 12]
- SEAndroid [NDSS 13]
- FlaskDroid [Security 13]
- ASM [Security 14]



# 识别UIP数据是前提



中国互联网安全大会



360互联网安全中心

## 如何识别UIP类数据是保护UIP类数据的前提

- 不是所有的用户输入都是同样敏感（支付密码 vs 搜索关键词）
- 识别APP中所有的UIP数据
- 并且识别接收UIP数据的控件





## UIP数据识别：UIPicker

- 自动化的识别APP中所有的UIP控件
- 自动化标识控件的ID
- 支持海量软件的分析

## UIP数据保护机制

- 防止UIP数据被中间人攻击
- 监测UIP数据是否经过HTTP传输
- 监测UIP数据是否经过不安全的HTTPs传输



# 如何识别UIP控件？

## 挑战

- 1、接受用户输入的界面很多
- 2、一个界面中存在多个接受用户输入的控件
- 3、接受用户输入的控件类型多样

## 这种方案是否可行？

- 根据控件定义的属性，例如：“android.inputType=**textPassword**”
- 是否能够很好的解决问题？

## UI控件会包含一些隐私相关的元信息

- UI控件上会包含敏感数据的说明
- 开发者对UI控件的命名会标示一些敏感数据信息

核心想法：

基于文本分析识别用户输入隐私控件

### Add a new credit card

Credit Card Number

Expiration Date: 01 2014

Card Type: MasterCard

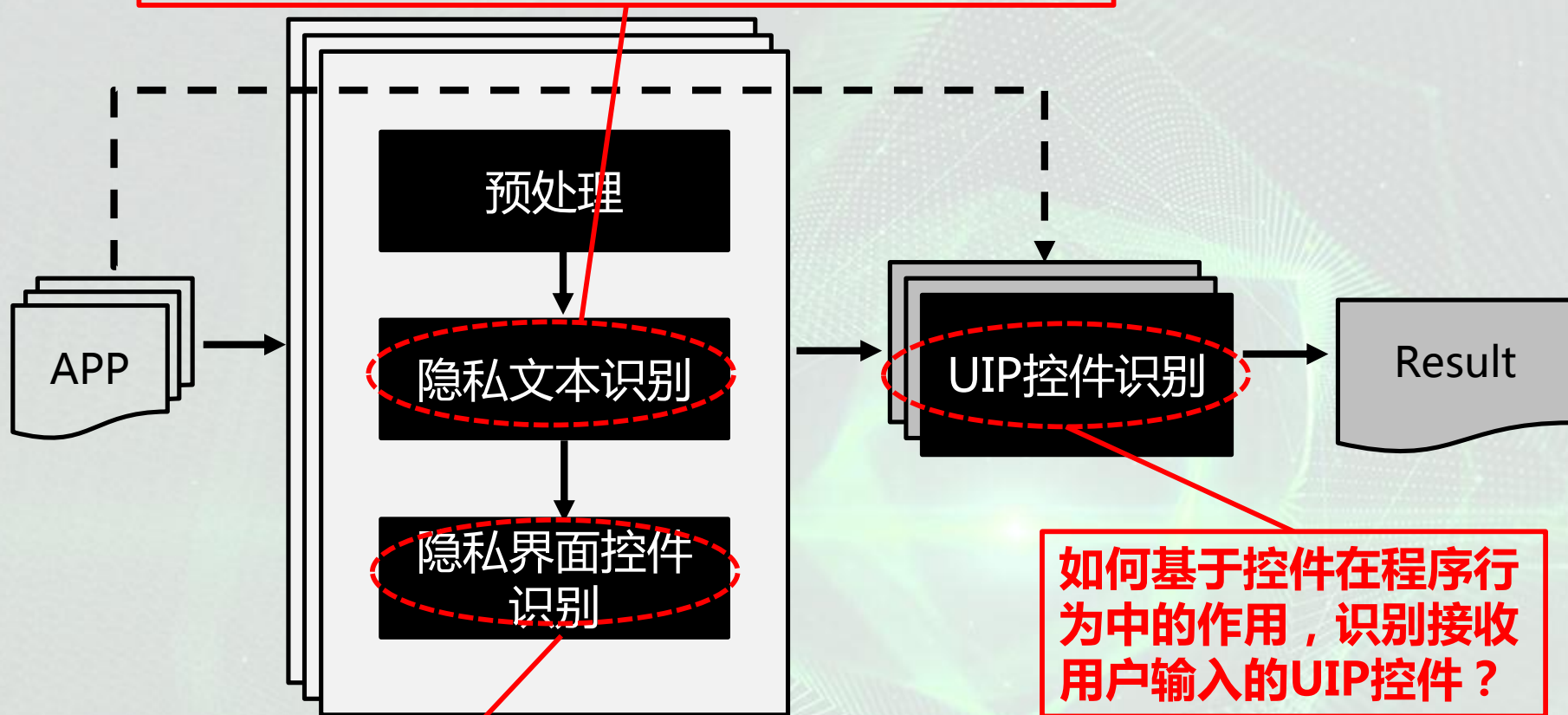
Cardholder's Name

Add your card

```
<TextView android:text="@string/opl_new_payment_credit_card_number" />  
<EditText android:id="@id/opl_credit_card_number" android:inputType="number" />
```



如何构建一个有代表性的、可以用于代表隐私信息的文本库？



如何基于控件在程序行为中的作用，识别接收用户输入的UI控件？

如何基于界面控件的相关文本信息，识别隐私界面控件？

## – 资源文件提取

- 界面上出现的文本
- 开发者定义控件的名称

## – 分词

- 基于分隔符和特殊字符

## – 清洗

- 非英语字符串、删除词

## – 词根提取(Stemming)

- 例如：将secured、security替换为secure

### 1 UI Texts

#### Add a new credit card

Credit Card Number

Expiration Date: 01 2014

Card Type: MasterCard

Cardholder's Name

Add your card

### 2 Layout Descriptions

@id/opl\_credit\_card\_number

@string/opl\_new\_credit\_card\_expiration\_date\_month

@string/opl\_new\_credit\_card\_save\_button

消除**开发者习惯**带来的隐私文本差异性

## 挑战：无法依赖人工定义一个很全的隐私文本集合

- 不同开发者会使用不同的词命名控件
- 不同的APP对于同样信息会有不同的文本表述
- 怎么找到尽可能多的能够描述一种用户隐私的文本？



## 我们的方法

- 人工定义一个初始的敏感文本集合 ( Initial Seeds )
- 基于初始集合，自动化的找到更多的类似的词

phonenumber  
email  
username  
password



mobil  
firstnam  
zipcod birthdat  
location address  
pay provinc nicknam  
account password mm  
zip yyyy  
code payment  
pwd citi pass  
street yy debit  
secur expir transact age mail  
bank male countri locat  
pin phone user birth  
femal contact email  
passwd usernam  
dd  
credit cellphon  
lastnam birthday

(1) Initial Seeds

(2) 较为完整的隐私文本集合

## 我们的发现：隐私文本不是孤立出现的

- 包含隐私文本的页面会出现多个隐私文本
- 例如：登陆页面（用户名、密码等）、账号设置页面（姓名、邮箱等）

## 分析方法

- 1) 基于Initial Seeds标记含有（不含有）隐私文本的界面
- 2) 基于Chi-test聚类识别能够显著区分一个界面是否敏感的文本

| UIP类型                            | Initial Seeds (7 words)   | Chi-test words (228 words)                                                                                         |
|----------------------------------|---------------------------|--------------------------------------------------------------------------------------------------------------------|
| Login Credentials & User Profile | username, password, email | mobil phone middl profile cellphon<br>account nicknam firstnam lastnam<br>person birth login confirm detail regist |
| Location                         | address, location         | zip citi street postal locat countri                                                                               |
| Financial                        | credit card, bank         | secur month date pay year bill expir debit<br>transact mm yy pin code                                              |

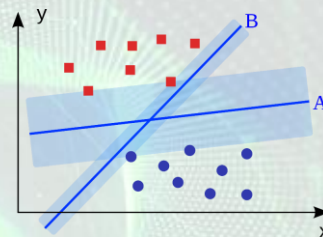
## 如何判断一个界面控件是否接受UIP数据

- 基于隐私文本判断一个UIP控件是否敏感

## 识别方法

### 1) 基于支持向量机 ( SVM ) 进行自动化分类

- 控件所属的隐私文本 → 特征值
- 涵盖控件左右邻居控件





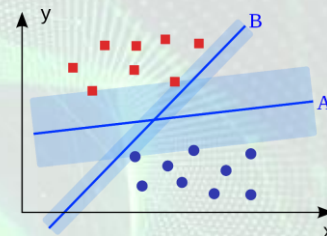
## 如何判断一个界面控件是否接受UIP数据

- 基于隐私文本判断一个UIP控件是否敏感

## 识别方法

### 1) 基于支持向量机 ( SVM ) 进行自动化分类

- 控件所属的隐私文本 → 特征值
- 涵盖控件左右邻居控件



### 2) 如何获取训练集合

```
<EditText android:id= "@id/password_edittext"  
android:inputType="textPassword" />
```

| UIP类型       | 训练集合识别方法                                                                                             |
|-------------|------------------------------------------------------------------------------------------------------|
| 登陆凭证 & 账户信息 | 控件属性：textEmailAddress, textPersonName, textPassword, textVisiblePassword, password/email/phoneNumber |
| 地理位置        | 控件属性：textPostalAddress                                                                               |
| 支付类信息       | 人工标记                                                                                                 |

## – 问题：不是每一个隐私界面控件都接受用户输入

- 如何识别一个隐私界面控件是否显示用户输入的隐私

## – 接受用户输入类型：

- 主动输入：EditText
- 被动输入：下拉菜单
- 定制化控件：com.alipay.InputBox

☒ Upload my address book to connect me with my friends.

**Sign Up**

By tapping "Sign Up" above, you are agreeing to the [Terms of Service](#) and [Privacy Policy](#), including [Cookies use](#).

Your email address and phone number may be used to connect you with others, but will not be

Expiration Date:

Card Type:

思路：基于程序访问含有隐私文本控件的行为

## 1、找到访问含有敏感文本信息的控件

`Activity setContentView(R.layout.add_credit_card.xml)`

Add a new credit card

UIP控件

Credit Card Number

Expiration Date: 01 2014

Card Type: MasterCard

Cardholder's Name

Add your card

```
Void onCreate(Bundle bundle){  
    InputBox IB = findViewById(2131231511);  
    submitBtn = findViewById(2131623982);  
    submitBtn.setOnClickListener(new addCardListener());  
}
```

## 2、识别用户交互行为

```
addCardListener.onClick(View v) {  
    .....  
    creditCard = IB.getText();  
}
```

UIP控件行为特征：

控件的文本信息会在某一个事件处理函数中获取



## TaintDroid系统[OSDI 2010]

- 基于动态污点分析技术跟踪敏感数据的传播
- 仅支持对通过系统API访问的隐私数据的保护

## UIP数据保护系统

- 1) 基于UIP控件标记隐私数据
- 2) 基于TaintDroid跟踪UIP数据的传播
- 3) 监测网络发送UIP数据的行为
  - 是否使用HTTP发送
  - 是否使用不安全的HTTPs发送

# 运行时UIP保护机制



中国互联网安全大会



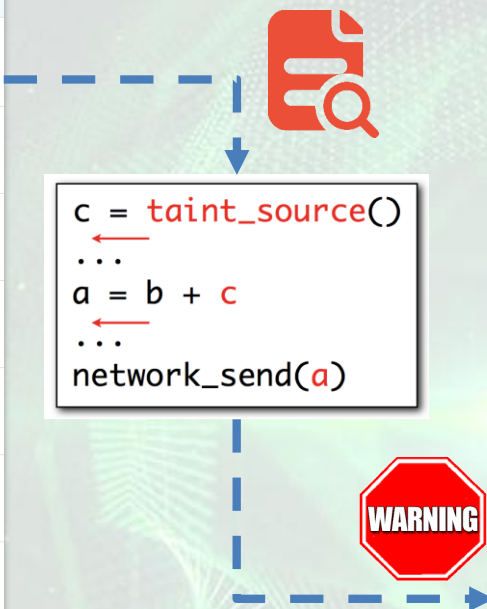
360互联网安全中心

< 银行卡支付

 中国银行(信用卡)  
6227 6121 4583 0440

|                    |       |                                                                                                                             |
|--------------------|-------|-----------------------------------------------------------------------------------------------------------------------------|
| 03/20              | 有效期   |                                            |
| 369                | 安全码   |                                            |
| bob                | 持卡人姓名 |                                                                                                                             |
| 身份证                | 身份证号  |                                            |
| 310109196509192811 |       |                                                                                                                             |
| 138 1839 9589      | 手机号   |                                                                                                                             |
| 727114             | 验证码   |  <input type="button" value="重获验证码(2)"/> |

☒ 同意《协议》并保存卡信息，支付更便捷



UIPicker

Application Name  
Qunar Travel

Package Name  
com.Qunar

Destination IP Address  
59.151.16.178

The following data will be insecurely sent:  
User Input Privacy  
727114, 369, bob, 310109196509192811,  
138 1839 9589, 13818399589, 6227 6121  
4583 0440,

DENY

ALLOW

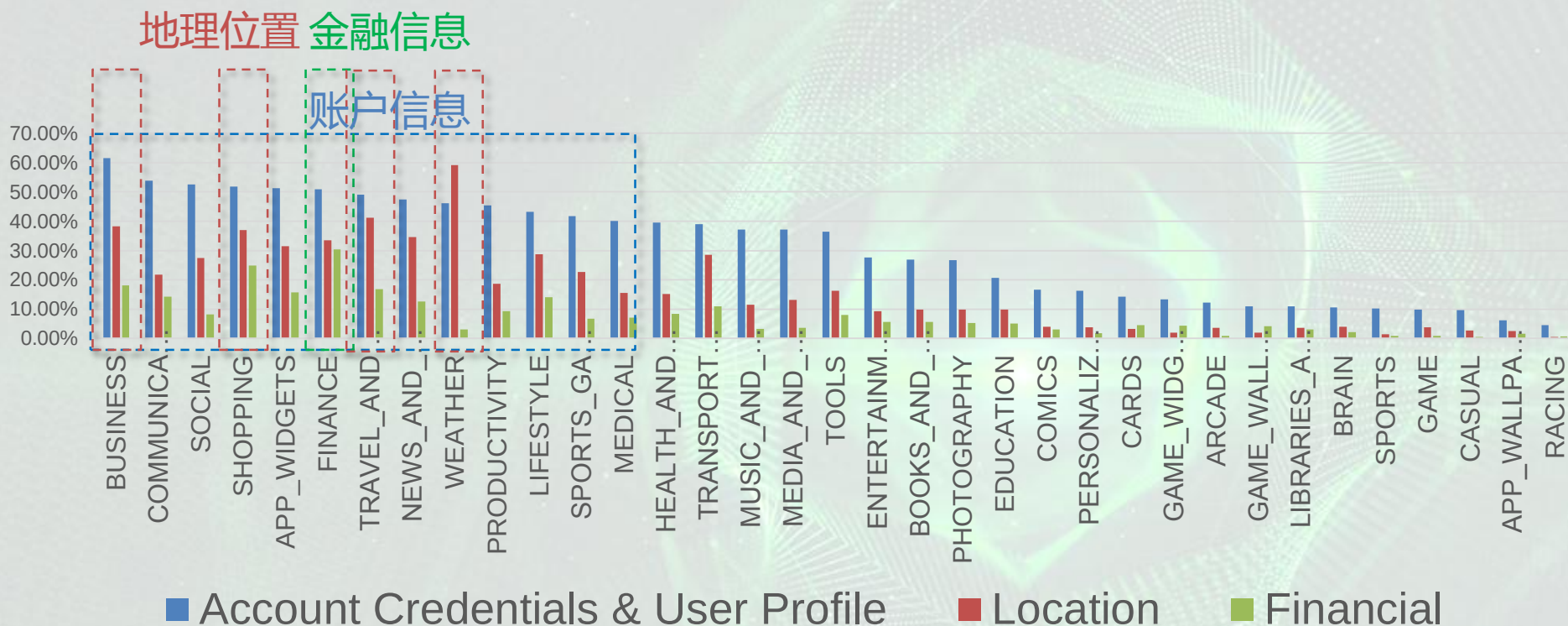
## 数据集

- 来自Google应用商城爬取的17,425 个应用
- 共35个类别，每一个类别500个应用



# UIP数据在APP中的分布

- 在17,425个APP中，35.46%的APP含有用户输入隐私
- 在35个类别中，有9个类别过半的APP含有用户输入的隐私



# 识别到了多少UIP数据

## 与采用控件属性相比

textEmailAddress, textPersonName,  
textPassword, textVisiblePassword,  
password/email/phoneNumber

textPostalAddress

| Category                           | InputType | UIPicker | Incremental |
|------------------------------------|-----------|----------|-------------|
| Account Credentials & User Profile | 24,021    | 46,227   | 26,087      |
| Location                           | 941       | 14,311   | 13,370      |
| Financial                          | -         | 6,353    | -           |
| Total                              | 24,962    | 71,224   | 46,262      |

15x

2x

# 识别到了多少UIP数据

## 一些静态UI控件也包含输入类的隐私

| Type       | # Elements | % in UIP Data |
|------------|------------|---------------|
| TextView   | 10,582     | 14.86%        |
| Customized | 5,075      | 7.13%         |
| Spinner    | 1,962      | 2.75%         |
| Others     | 784        | 1.10%         |
| Total      | 18,403     | 25.84%        |



- 验证集合：随机从10个类别中各选取20个应用，共200个应用

| UIP类型  | True Positive | False Positive | False Negative |
|--------|---------------|----------------|----------------|
| 人工验证结果 | 975           | 67             | 107            |

- 结果：

➤ 精度度：93.6%

➤ 召回率：90.1%

$$Precision = \frac{TP}{TP + FP} \quad Recall = \frac{TP}{TP + FN}$$

- 由于移动平台极其开放的生态环境，移动平台上用户隐私**面临严重威胁**
- 用户**输入类隐私**是移动平台的一大特点，现有工作尚未很好的对用户输入类隐私进行保护
- 用户输入类隐私格式各异、接口非规整、获取形式多样，对其进行**系统化的识别十分困难**
- **基于界面文本分析的方法**可以很好的识别界面中包含输入类隐私，从而有效保护用户输入类隐私

# 谢 谢



中国互联网安全大会



360互联网安全中心